

Anatomía de un cuestionario enterprise de seguridad

Lo que te van a pedir y qué responder

Fernando Hurtado

Fractional CISO · AI Governance

Este cuestionario va a llegar.

Cuando le vendes a un Fortune 500, cuando tu cliente tiene SOC 2 y audita a sus proveedores, o cuando un partner financiero te evalúa. 40 a 200 preguntas, sin avisar. Conviene conocer su estructura antes.

Gobernanza y datos

- 1 Políticas:** ¿hay política de seguridad aprobada y vigente? Evidencia: documento con fecha y responsable.
- 2 Accesos:** ¿MFA, mínimo privilegio, revisión periódica? Evidencia: capturas + registro de revisiones.
- 3 Datos:** ¿cifrado en tránsito y en reposo? Evidencia: configuración documentada.

Operación y compliance

- 1 Continuidad:** ¿plan de incidentes y backups probados? Evidencia: plan + último test.
- 2 Vendor risk:** ¿evalúas proveedores, incluidos LLMs? Evidencia: inventario + contratos.
- 3 Privacidad:** ¿GDPR / HIPAA / LFPDPPP según mercado? Evidencia: avisos + DPAs.

4 respuestas que frenan deals

- 1 “Lo estamos por implementar.” (sin fecha)
- 2 “Confíen en nosotros, es seguro.”
- 3 “Eso lo maneja nuestro proveedor de nube.”
- 4 “No lo tenemos documentado todavía.”

LO QUE VE PROCUREMENT

No pide perfección; pide evidencia. 'En proceso' sin fecha = red flag.

Minimum viable governance

Sin ser certificable aún

- 1 **Política maestra** + 3-4 específicas, aprobadas.
- 2 **Inventario** de accesos y de proveedores.
- 3 **Plan de incidentes** de una página.
- 4 **Un dueño ejecutivo** que responda el cuestionario.

EL RESULTADO

Con esto respondes el 80% de un cuestionario sin tener certificación.

¿Vendes (o quieres vender) a enterprise?

Guarda esta anatomía y compártela con quien lidere ventas o compliance.

cal.com/fernando-hurtado

Fernando Hurtado

Fractional CISO · AI Governance